대외비 2급

정보자산관리 지침서

2012. 02

연세대학교 의료원
YONSEI UNIVERSITY HEALTH SYSTEM

제 개정 이력

제 개정번호	일자	제 개정 내용 요약	작성자
2012-01	2012-02-22	ISO27001 인증 대비 전면 개정	조남인
2016-01	2016-01-29	[별지 제2호 서식] 서식 및 문구 변경	조남인
2016-02	2017-01-16	자산분류 수정, 자산 중요도 평가방식 변경	조남인
2020-01	2020-11-04	제8조(자산의 관리) 문구 수정 제9조(자산의 운용) 출력시 표기 내역 수정	조남인
2022-01	2022-05-03	제11조(정보자산의 폐기 및 용도변경) 부서명 변경	조남인
2023-01	2024-01-08	제5조(자산의 식별과 분류) 문구 수정 제10조(자산 반출입 절차) 문구 수정	조남인
2024-01	2024-12-23	제8조(자산의 관리) 문구 수정	조남인

목 차

제1조 (목적)..... 3

제2조 (적용범위)..... 3

제3조 (용어정의)..... 3

제4조 (책임 및 역할)..... 4

제5조 (자산의 식별과 분류)..... 4

제6조 (자산 평가 목적)..... 6

제7조 (자산의 중요성 평가 및 관리)..... 6

제8조 (자산의 관리)..... 7

제9조 (자산의 운용)..... 8

제10조 (자산 반출○입 절차)..... 9

제11조 (정보자산의 폐기 및 용도변경)..... 9

제12조 (중요 정보자산의 유지보수 및 장애 관리)..... 10

제13조 (시행과 갱신)..... 10

제1조 (목적)

본 지침서는 연세대학교 의료원 (이하 산하기관 모두 포함하여 '의료원'이라 칭함)의 중요 정보자산을 효과적으로 보호하기 위해 자산을 분류하고, 자산 목록을 작성 및 관리함으로써 담당자 업무별로 책임과 권한을 명시하여 정보시스템이 항상 최상의 상태로 가동되도록 한다.

제2조 (적용범위)

① 본 지침서는 의료원 정보시스템의 개발 및 도입, 운영, 이용, 유지보수, 매각, 폐기에 대한 모든 활동에 대하여 적용한다.

② 정보시스템 관리에 관한 사항은 특별한 지침서가 있는 경우를 제외하고는 본 지침서에 적용된다.

제3조 (용어정의)

본 지침서에서 사용하는 용어의 정의는 다음과 같다.

① 서비스: 서버에서 제공되는 데이터를 가공하여 사용자에게 제공하는 소프트웨어.

② 서 버: 서비스가 장비에서 동작할 수 있도록 하는 하드웨어.

- 정보시스템: 컴퓨터의 본체, 주변장치 및 단말장치 등의 전부 또는 일부로써 구성되는 하드웨어 및 데이터베이스, 서버, 네트워크 및 정보보호시스템, OCS/EMR/ERP, ESS, GW, CDR, PACS등 프로그램을 총칭한다.

③ 전산부대설비: 컴퓨터 가동을 지원하기 위하여 설치되어 있는 각종 부대설비를 말한다.

④ 서버실: 전산시스템이 설치되어 있는 장소를 말한다.

⑤ 본 지침서에서 정의되지 않은 용어의 정의는 일반적인 전산용어 정의에 따른다.

제4조 (책임 및 역할)

① 자산감독책임자: 자산을 직접 생성·생산 및 구매·도입 업무를 주관하는 부서장으로서 의료원 자산을 관리할 책임과 권한을 갖는다.

② 자산관리책임자: 자산감독책임자로부터 책임과 권한을 위임받아 관리하는 자로서 각 부서장을 말하며. 자산관리책임자는 정보자산 소유자로서 관할 정보자산을 보호할 책임과 권한을 갖는다.

③ 자산제공자: 자산감독책임자가 지정한 자로서 자산감독책임자의 지시에 따라 자산의 보호 및 관리요건을 구현하고, 자산 사용자에게 필요한 자산을 제공한다.

④ 서비스운영자: 사용자에게 서비스를 제공하고 관리한다.

⑤ 자산 사용자: 자산을 실질적으로 사용하는 자를 말하며, 제공받은 자산을 보호해야 할 궁극적인 책임을 갖는다.

제5조 (자산의 식별과 분류)

① 본 의료원 정보자산의 유형은 다음 표와 같이 정의한다. <개정 2017.01.16>

구분	내용
문서	• 의료원이 보유하고 있는 소프트카피나 하드카피의 문서(기밀/대외비 문서)
소프트웨어(상용)	• 의료원이 운영하고 있는 상용 프로그램 (라이선스 보유 등) 예) O/S, 개발 유틸리티, 백신, 유지보수 소프트웨어, MS오피스 등
어플리케이션	• OCS/EMR의 운영을 위하여 직접적으로 관련된 응용프로그램 (Application)
서버	• 보안시스템을 제외한 의료원이 보유하고 있는 서버장비
네트워크	• 의료원이 보유하고 있는 라우터, 스위치 등 네트워크 장비

구분	내용
보안시스템	• 의료원이 보유하고 있는 방화벽, IPS 등 정보보호 시스템
DBMS	• 방대한 양의 데이터를 체계적으로 관리하는 소프트웨어
WEB / WAS	• WEB : 사용자에게 웹서비스를 제공하기 위한 서버 (예 아파치, IIS, 등) • WAS : Web Appication Server (예 JEUS, Tomcat, WebLogic등)
부대설비	• UPS, 항온항습기, 출입통제시스템 등의 장비
기타 자산	• 저장매체 (외장하드, USB 등, 백업테이프) • 백업장비 (NAS등) • 스토리지 서버
인적자산	• 의료원 정보 시스템 운영 및 개인정보 취급 인력
PC	• 인적자산이 업무용으로 사용하는 개인컴퓨터, 노트북 등
웹/앱 서비스 (대외서비스)	• 홈페이지(대외서비스) 및 모바일 앱(대외서비스)

② 이와 관련된 상세 분류 기준은 다음과 같다.

분류	상세분류	자산 샘플 목록
정보	전자 정보	• 금융 정보, 개인 정보, 환자 정보, 조직 기록, 증거 자료, 소스코드 등 • 업무 내규 및 절차 등 • 계약서, 소프트웨어 문서, 시스템 문서, 운영 절차, 교육 자료 등
	출력물, 인쇄물, 종이	
S/W 자산	운영체제	• 벤더 별 운영체제(Sun, HP, Microsoft 등)
	사무자동화	• 그룹웨어, 오피스 군 등
	업무 어플리케이션	• OCS, EMR, ERP, CDW, PACS 등

분류	상세분류	자산 샘플 목록
	보안 및 통신 소프트웨어	• 방화벽, IPS, VPN 등
	기타 지원 소프트웨어(개발,관리,지원 등)	• 개발 유틸리티, 업무 지원 및 관리, 유지보수 소프트웨어 등
H/W 자산	컴퓨터 및 컴퓨팅 자원	• 서버, PC, 중요 컴퓨팅 자원 등
	백업장비	• SAN, NAS 등
	접속 및 네트워크 장비	• 라우터, 스위치, L4 등
	보안 장비	• 방화벽, IPS, VPN, 통합PC보안관리시스템, 바이러스월, TMS, DDoS 장비, 웹 방화벽, 유해사이트차단시스템 등
부대설비 자산	전기 공급 장치	• UPS 등
	항온항습 및 조명, 냉난방(HVAC)	• 항온항습장치 등
	기타 부대설비 자산	• 방재, 누수 탐지 등

제6조 (자산 평가 목적)

① 자산이 적절한 수준의 보호를 받는 것을 목적으로 한다.

② 자산 분류는 적절한 보호 단계를 정의하는 데 쓰여야 하며, 특별한 처리를 요하는 경우에 대하여도 적용할 수 있어야 한다.

③ 자산은 중요성의 정도에 따라 달리 취급되며 분류 등급이 1등급인 경우에는 추가적인 보호와 강화된 처리를 요구할 수 있는 바 상기 ②항에서 말하는 “특별한 처리”란 이러한 추가적인 보호와 강화된 처리를 말한다.

제7조 (자산의 중요성 평가 및 관리)

① 자산의 중요성은 개별 정보자산이 업무에 미치는 영향의 범위 및 파급도를 고려하여 기밀성, 무결성, 가용성 관점에서 중요도를 평가한다. 이를 위해 “[별표1] 자산 평가 기준”과 “[별표2] 자산 평가 시 고려사항” 적용하되, 구체적으로 명시되지 않았더라도 유사한 영향이 있다고 판단되는 경우 해당 등급을 부여할 수 있다.

② 개별 자산 중 자산 중요도를 고려하는 자산에 대하여 위와 같은 기준을 바탕으로 각각 기밀성, 무결성, 가용성의 요구 정도를 상, 중, 하로 평가한 후, 개별 정보자산에 대한 중요도 등급은 보안 요구 정도를 상(3), 중(2), 하(1)로 치환한 후 합산하여 산출한다. 이를 수식으로 나타내면 다음과 같다.

③ 중요도 등급 = 기밀성(3, 2, 1) + 무결성(3, 2, 1) + 가용성(3, 2, 1)

④ 중요도 등급 분류는 아래 표와 같다.

중요도 등급	자산 중요성 지수 범위
H (3)	8 점 ~ 9 점
M(2)	6 점 ~ 7 점
L(1)	3 점 ~5 점

제8조 (자산의 관리)

① 자산의 관리는 각 부서 단위로 하는 것을 원칙으로 한다.

② 자산의 관리책임은 다음을 따른다.

1. 개별 자산에 대한 관리 책임은 자산감독책임자에게 있다. 정보보호 주관부서는 매년 자산 관리 실태를 파악한 뒤 중요한 이슈가 있는 경우 최고정보보호책임자에 보고한다.
2. 자산감독책임자는 자산 제공자와 자산관리책임자에게 자산 관리에 대한 실행 책임을 위임할 수 있다.

3. 자산관리책임자는 자산을 새로 도입하거나 생성하는 경우 정보자산의 식별, 정보자산의 분류, 정보자산의 중요성 평가, 등급분류 등을 '별첨1. 자산목록 및 중요도 평가서'에 기록하여 관리한다.
4. 자산관리책임자 (정보보호관리자(각 부서장))는 주기적으로 소관부서의 정보자산을 파악해야 하며, 정보보호 주관부서에서 요청 시 제출해야 한다.
5. 자산 사용자의 고의나 중대한 실수로 발생한 사고에 대해서는 자산사용자가 1차적인 책임을 지며 자산관리책임자가 2차적 책임을 진다.

제9조 (자산의 운용)

① 자산관리책임자는 신규로 등록되는 정보자산에 대하여 해당 정보자산의 관리를 위한 규정이 존재하는지 확인하고, 해당 규정이 없는 경우 정보자산 취급지침 및 관리절차 등 새로운 규정을 수립하여 정보보호실무책임자에게 건의한다.

② 자산감독책임자는 등록된 자산에 대해 취득일자, 모델명, 부서명 등을 기재하여 라벨로 부착한다.

③ 전산 출력물에는 해당부서, 출력일시, 사용자가 명확인 표시되어 출력되어야 한다. 필요 시 기밀(대외비 1급/2급) 문서에 대해서는 별도의 표시되어 출력되도록 추가할 수 있다.

④ 의료원 교직원은 원내에서 기밀로 관리하는 자산을 전자문서 형태로 외부에 전송할 수 없다. 대외비 이상의 문서인 경우 "문서 및 매체보안지침서"의 에 의거하여 승인 후 전송한다.

⑤ 외부로 FAX를 사용해 기밀문서를 발신하는 것은 금지하며, 대외비 이상 문서를 발신할 경우 "문서 및 매체보안지침서"에 준하여 승인 절차를 거쳐 발신한다.

⑥ 타 의료원 및 외부 기관과 정보 및 소프트웨어의 교환 협정 및 지적 재산권 보호에 따른 정보 자산 관리 절차는 아래와 같다.

1. 업무적 계약관계나 협약에 의해, 또는 이에 준하는 명시적 협력관계에 의해 제공받은 타 의료원 또는 외부기관의 영업비밀 정보자산에 대해서는 대외비에 준하는 관리를 해야 한다.
2. 타 의료원 또는 외부기관의 정보자산은 해당 업무의 목적으로만 사용해야 한다.
3. 별도의 NDA(Non Disclosure Agreement : 비밀유지계약)를 맺은 경우 그 협약 내용에 따라 관리해야 한다.

⑦ 자산감독책임자 또는 자산관리책임자는 관련 규정에 따라 정보자산이 사용 및 운용되고 있는지 관리 감독한다.

⑧ 자산의 취득 시 “자산관리규정”을 따른다.

제10조 (자산 반출□입 절차)

① 서버, 업무용 PC와 모바일 자산은 다음 절차에 따라 반출□입 하여야 한다.

1. 해당업무 자산관리는 자산의 반출□입이 있는 경우 “자산관리규정”에 따라 자산관리책임자에게 자산 반출□입을 요청한다.
2. 반출□입 시 해당 업무 자산관리책임자는 중요 정보 포함여부를 확인 후 반출□입하여야 한다. 특히, 자산을 외부에 반출 시 수록된 중요 자료를 소자(消磁)한 후 반출하여야 한다.

② 자산관리책임자는 자산의 반출입시 “[별지 제1호 서식] 전산장비 반입 반출 관리대장" 을 작성한다.

제11조 (정보자산의 폐기 및 용도변경)

① 자산관리책임자는 등록된 정보자산을 폐기하거나 용도 변경하는 경우 해당 자산관리규정에 따라 이를 행하며 해당 정보자산에 대한 정보를 변경한다.

② 자산의 용도 변경 시 저장된 정보가 하위 레벨로 초기화하는 등의 방법으로 영구 복구

불가능하도록 완전 삭제한다.

③ 기증용 PC는 정보가 영구 복구 불가능하도록 조치를 취한 후 기증한다.

④ 자산의 폐기 시 정보보호 주관부서에서 저장된 정보가 영구 복구 불가능하도록 완전 삭제하거나, 구매팀에서 저장된 기록 매체에 대해 영구사용 불가능하도록 물리적으로 파기하여 해당 자산을 매각 또는 폐기한다.

⑤ 자산 폐기 결정기준과 폐기 처리는 "자산관리규정"을 따른다.

제12조(중요 정보자산의 유지보수 및 장애 관리)

① 시스템 장애 대응

1. 서버 별 유지보수 관계철을 참고하여 시스템 장애에 대처하여야 한다.
2. 장애대응관련 내용은 'u-Severance 장애대응가이드이나 '장애 유형별 장애 처리가이드'를 참조한다.

② 시스템 유지 보수

1. 전산시스템 자원이 충분한 기능을 발휘할 수 있도록 매년 유지보수 계획을 수립 및 시행하여야 한다.

③ 전산(부대)시설 관리

1. 전원 시설의 확보
2. 항온항습기의 용량 확보
3. UPS의 용량 확보
4. Battery의 용량 확보

제13조(시행과 갱신)

상기 지침서의 시행과 갱신을 위한 상세한 세부사항은 정보보호규정 '제4장 정보보호 정책'에 준한다.

[별지 제1호 서식] 전산장비 반입 반출 관리대장

전산장비 반입 반출 관리대장

관리 담당	관리 PL	관리 PM

No.	일시	소속	성명	장비 품목	파트 (부품)	사유	반입 / 반출	담당자 확인
1							반입 / 반출	
2							반입 / 반출	
3							반입 / 반출	
4							반입 / 반출	
5							반입 / 반출	
6							반입 / 반출	
7							반입 / 반출	
8							반입 / 반출	
9							반입 / 반출	
10							반입 / 반출	

별첨1. 자산목록 및 중요도 평가서

[별표1] 자산 평가 기준

수준	점수	내용		
		기밀성(Confidential)	무결성(Integrity)	가용성(Availability)
상 (H)	3	▪ 자산이 유출되는 경우 전사적으로 중대한 손실을 미치는 경우 ▪ 자산소유자인 해당부서 또는 담당자만이 접근 및 관리 가능한 자원	▪ 정보자산 변조시, 업무수행 또는 서비스에 중대한 장애를 유발하거나 회사전체에 중대한 손실을 입히는 경우 ▪ 정보자산 변조의 가능성이 높고 변조 시 데이터의 무결성을 검증하기 힘든 경우	▪ 장애발생시 즉시 복구되어야 하는 경우 ▪ 해당 자산에 대한 장애 또는 침해사고 발생시 직접적인 서비스 중단을 야기하는 경우
중 (M)	2	▪ 자산이 유출되는 경우 회사에 부분적인 손실을 미치는 경우 ▪ 자산소유부서/담당자 이외 관련부서 등 회사 조직 내부에 국한하여 접근 및 열람이 가능한 정보를 가지고 있는 자산	▪ 정보자산 변조 시, 업무수행 또는 서비스에 부분적인 장애를 유발하는 경우 ▪ 데이터 변조의 가능성은 있으나, 데이터 변조 시 무결성 검증이 가능한 경우	▪ 장애 발생 시 1시간 이내에 복구되어야 하는 경우 ▪ 장비 장애로 인하여 서비스 중단은 발생하지 않으나 성능에 영향을 미치는 경우
하 (L)	1	▪ 회사 조직 외부인이 접근 및 열람이 가능한 정보를 담고 있는 자원 ▪ 해당 자산(장비)에 별도 정보가 기록되어 있지 않거나, 공개되어도 무방한 경우	▪ 자산이 변조되어도 업무 수행에 미치는 영향이 미흡한 경우 ▪ 자산에 포함된 정보의 변조 가능성이 희박하고, 정보 변조 시 무결성 검증이 용이한 경우	▪ 장애 발생 시 수시간 이내에 복구되어야 하는 경우 ▪ 장비 장애 시 서비스 중단 또는 성능 저하에 직접적인 영향을 미치지 않는 경우

[별표2] 자산의 가치 평가 시 고려사항

손실등급	재정적	이미지 손실	개인정보침해	사업 경쟁력	업무 운용
1 등급(VH)	십억원 이상	전국적 규모로 이미지 손실 발생 및 심각한 적대적 평판/ 여론 발생	해당사항 없음	의료원의 사활이나 경쟁력 있는 특정 분야 자체의 존립에 영향을 줄 수 있는 경우	해당 사항 없음
2 등급 (H)	일억원 이상 십억원 이하	전국적 규모로 고객, 정부, 관련 기관으로부터 이미지 손실 발생	법・규약으로 보장된 신상 정보 중 특히 민감한 정보의 불법적 노출이 발생하는 경우	중요 사업 성과에 심각한 악영향을 끼치거나 경쟁력의 심각한 손상을 가져오는 경우	기술/ 회계/ 재무 면의 중요 운용업무에 심각한 영향을 가져오거나 장기적인 사업 방향의 노출을 가져오는 경우
3 등급(M)	천만원 이상 일억원 이하	특정 지역 내에서 고객, 정부, 관련 기관으로부터 이미지 손실 발생	법・규약으로 보장된 신상 정보 불법적 노출이 발생하는 경우	사업 성과를 저해하거나 경쟁력 약화, 사업 서비스에 악영향을 가져오는 경우	전체 조직 운용과 관리에 지장을 초래하거나 단기적인 사업 방향의 노출을 가져오는 경우
4 등급 (L)	백만원 이상 천만원 이하	조직 내에서 이미지 손실 발생	법・규약과는 무관한 신상 정보 불법적 유출이 발생하는 경우	사업 성과 및 경쟁력에 대한 약간의 손실 영향이 발생된 경우	특정 부서 업무에 약간의 지장을 초래